



MCP
Dev Summit
Toronto

Beyond the Prototype.

MCP Gateway Playbook for the Agentic Economy

Karen Bennet &
Mark Paulsen |
Toronto - October 6



Brief Introductions – Karen Bennet



**Co-Lead of SPDX
Ai and Dataset.**



**Vice Chair – AI
Working Groups
and Committee**



**Engineering
Executive**

Open Source Projects: Linux Foundation SPDX, AaIF, OpenSSF, AI and Data, FinOS, OASIS Cosai, OWASP AI /Agent BOM, SG V&V, Korea (Agent BOM).

Standards Work: Ai Expert for ISO, IEEE, EU CRA China policies/frameworks, OpenStandards, LF SPDX OpenSSF, AI and Data

Brief Introductions – Mark Paulsen



**Head, Open Source
Program Office
(OSPO)**



**Governance
(including AI) and
Platform
Engineering**

**Note: They don't
just sell tires.**



GitHub

**Global Director,
Enterprise
Advocacy**



Ex Internal Auditor as well

Production-Grade MCP for Regulated Finance

Solving the “lethal trifecta” of identity, exfiltration, and privilege escalation with a Gateway Registry Architecture.

Market Data



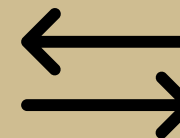
Real-time insights and research

Risk Assessment



Exposure, positions, and models.

Trade Execution



Controlled and Governed



Four Guardrails to Consider

1. **Authorization & Identity**
2. **Governance & Policy**
3. **Provenance & Attestations**
4. **Audit & Observability**

Shared by David Soria Parra (co-creator of MCP) at the FINOS AI Event in London, 2026



Why This Matters: AI Agents Meet Regulated Finance

The financial industry is deploying MCP to power AI agents across three high-stakes workflows where mistakes are expensive and auditors are watching

Market Data



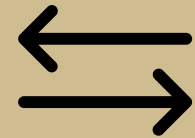
Real-time feeds and research across MCP servers for analyst copilots

Risk Assessment



Reason over exposure, positions, and models with decisions flowing into risk reporting

Trade Execution



Agents that can trigger real capital movement and must be tightly governed

Gateway Registry Pattern

A Central Registry for discover, paired with a Gateway for unified and enforced security controls.

Server Registry

- Catalog of Approved MCP Servers & Tools
- Ownership & Data Classifications
- Provenance
- SPDX SBOMs Per Server

Discovery



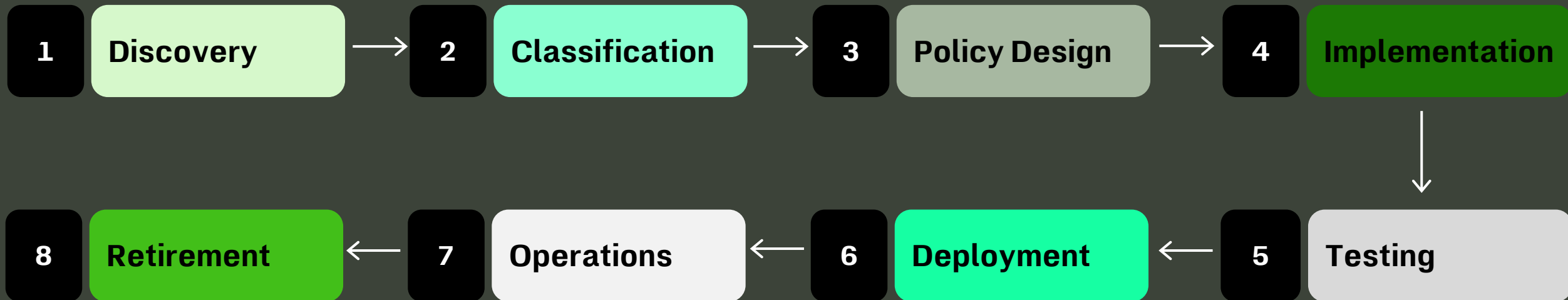
Security
Policy

Gateway

- OAuth2 Identity
- Role-Based Permissioning
- Threat Modeling & Policy Enforcement

The Gateway Playbook

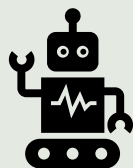
■ A Structured Path to Production: Eight phases for deploying an MCP gateway safely into a regulated environment



1. Discovery

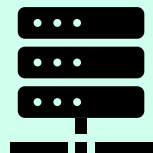
■ Why it matters: you can't govern what you haven't catalogued.

Inventory Agents



Deployed & planned agents,
owners, and workflows

Inventory Servers



Internal & Third-party
servers, version, maintainer

Inventory Tools



Tool surface, read, write,
execution capabilities

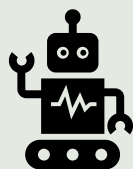
Inventory Data Sources



Market data, positions, client
records, order systems.

2. Classification ■ Why it matters: risk tiering drives every later policy decision.

Autonomy Level



Read-only, human-in-the-loop, or autonomous

Blast Radius



Worst case if Agent acts on bad input

Data Sensitivity



Public vs client PII vs non-public information

Risk Tier Assignment



Combine autonomy + blast radius = sensitivity into a tier

3. Policy Design ■ Why it matters: policy turns risks into enforceable rules.

Authorization



Who may involve which tool,
under what conditions

Governance



Approval workflows for new
servers and tools

Provenance



SPDC SBOMs tie server to
components and licenses

Audit Requirements



Logging, retention and
evidence mapping

4. Implementation ■ Why it matters: turn policy into working controls.

Build Gateway



Security controls, policy engine, observability

Integrate Registry



Approval workflows for new servers and tools

Connect MCP Servers



Approve and onboard tools and data sources

Enable OAuth2 & RBAC



Identity, tokens, role-based access

Policy As Code

■ Addressing Guardrails for the Gateway Registry

Turning the Guardrail Gaps into one Enforceable and Portable Policy that the Gateway calls to Evaluate Every Request.





MCP
Dev Summit
Toronto

Four Guardrails, One Rego Module

■ Authorization & Identify

Confirms the agent's signed identity.

■ Provenance & Attestation

Confirms the agent's model and tool manifest are complete.

■ Governance & Policy

This is the guardrail!

■ Audit & Observability

Builds one evidence record for every call.



opa check clean • 5 / 5 opa test passing

```
package mcp.gateway.authz

# GUARDRAIL 1 – Authorization & identity
identity_verified if {
    startswith(input.agent.spiffe_id, "spiffe://")
    input.agent.identity_token.verified == true
}

# GUARDRAIL 2 – Provenance & attestation (chained)
attestation_chained if {
    last := data.registry.last_attestation_hash[id]
    input.agent.agbom.prev_attestation_hash == last
}

# GUARDRAIL 3 – Governance & policy (this module, versioned)
policy_version := "2.4.0"

# GUARDRAIL 4 – Audit & observability (every call)
audit_event := {
    "agent_id": input.agent.agent_id,
    "decision": decision.allow,
    "reason": decision.reason,
}

# Hierarchy: safety > security > contractual > org
decision := {"allow": false, ...} if {
    input.agent.agent_id in
        data.gateway_config.safety_hold_agents
} else := {"allow": true, "reason": "granted"}
```

5. Testing

■ **Why it matters:** validate security, compliance, and performance before you scale.

Functional



Tool access, payloads,
policies

Security



Pen Testing, red teaming,
malicious inputs

Compliance



Audit trails, evidence
validation

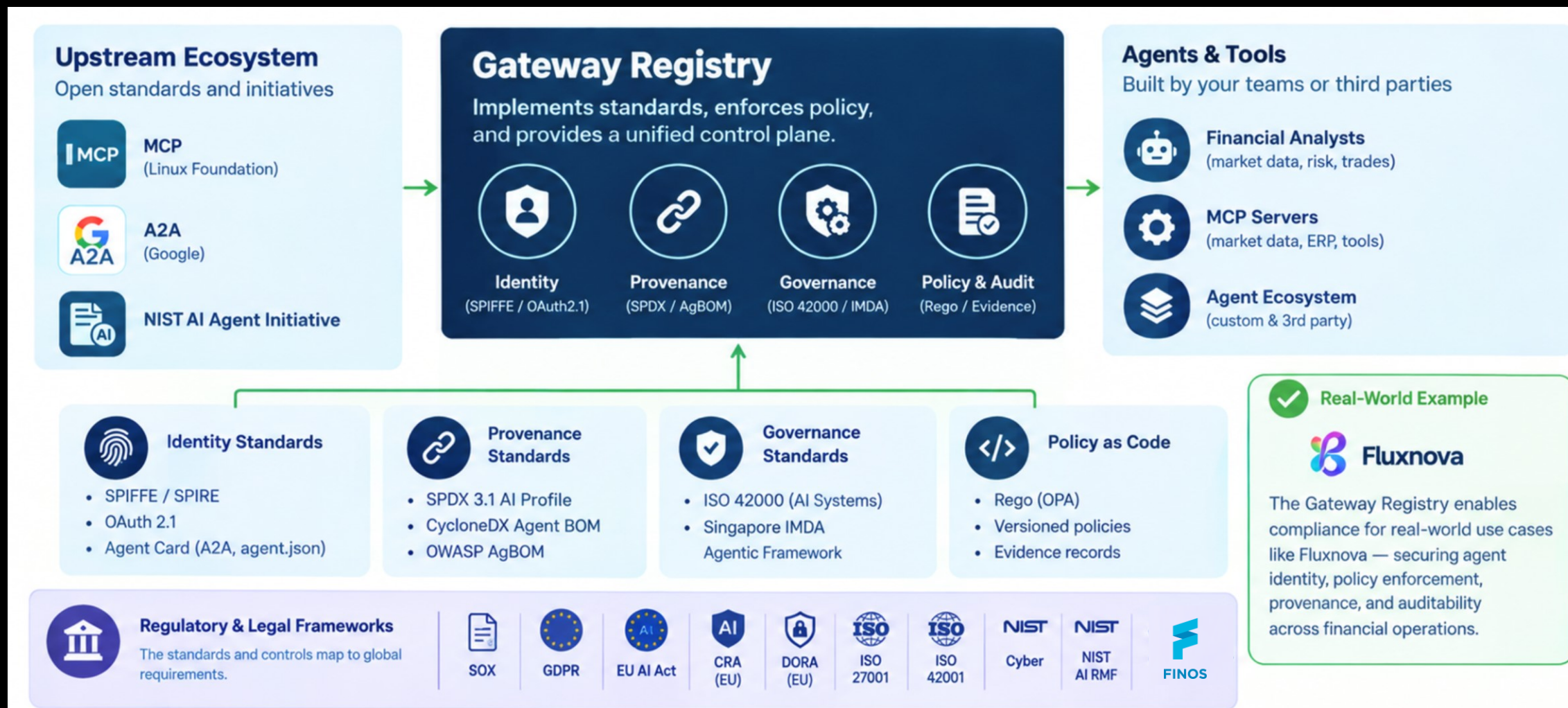
Performance



Load, latency, context usage



Standards and Regulatory Alignment



Out Of The Box Mapping

Guardrail	Framework	Relevant area	Why it maps
Identity	COBIT 2019	DSS05.04 Managed user identity and logical access; APO13 Managed Security	Identity lifecycle, logical access, security monitoring
Identity	NIST CSF 2.0	Govern / Protect	Governance of identities; access control and authentication
Identity	NIST AI RMF 1.0	Govern / Map / Manage	Roles, accountability, context, human oversight and risk treatment
Identity	ISO/IEC 27001	Access control / identity management	Unique identity, authentication, authorization and lifecycle
Identity	ISO/IEC 42001	AI management system	Accountability, governance and traceability for AI use
Identity	DORA	ICT risk management / access controls	Identity, access restriction and operational resilience
RBAC	COBIT 2019	DSS05.04; DSS06; APO12	Least privilege, business-process controls, risk management
RBAC	NIST CSF 2.0	Protect	Identity management, authentication and access control
RBAC	NIST AI RMF 1.0	Map / Manage	Context, risk tolerance, human oversight and risk treatment
RBAC	ISO/IEC 27001	Access control / change management	Least privilege and controlled changes
RBAC	EU AI Act	Risk management / logging / human oversight	Relevant for high-risk AI controls; applicability depends on system classification

RBAC	DORA	ICT risk / logical access / change management	Dynamic authorization and controlled privileged actions
Audit & Evidence	COBIT 2019	MEA02/MEA03/MEA04; DSS01/DSS05	Internal control, compliance, assurance, logging and monitoring
Audit & Evidence	NIST CSF 2.0	Govern / Detect / Respond	Continuous monitoring, incident analysis and response
Audit & Evidence	NIST AI RMF 1.0	Measure / Manage	Measurement, documentation, monitoring and risk response
Audit & Evidence	ISO/IEC 27001	Logging/monitoring; incident management	Evidence integrity, monitoring and investigation
Audit & Evidence	EU AI Act	Logging / documentation / human oversight	Traceability and evidence for applicable high-risk systems
Audit & Evidence	DORA	Logging / ICT risk / incident management	Event logging and auditability for financial entities
SPDX / AgBOM	COBIT 2019	BAI10 Managed configuration; APO14 Managed Data; APO10 Managed Vendors	Configuration, asset/data and supplier visibility
SPDX / AgBOM	NIST CSF 2.0	Identify / Protect / Govern	Asset inventory, supply-chain risk and governance
SPDX / AgBOM	NIST AI RMF 1.0	Map / Measure	System context, provenance, measurement and traceability
SPDX / AgBOM	ISO/IEC 42001	AI lifecycle / risk management / documented information	AI system inventory, lifecycle and traceability
SPDX / AgBOM	CRA (EU)	Cybersecurity / vulnerability and supply-chain transparency	Software composition and security evidence can support obligations where applicable

Agentic AI Standards Under Development

Active projects addressing AI agents, status as of September 2026

IEEE

Active PARs · IEEE SA

P3709	Agentic AI framework & technical requirements
P3394	LLM agent interface
P3777	AI agent benchmarking & metrics
P3428	LLM agents for education
P3833	Proactive multimodal AI agents
P3794	Knowledge-management agents
P3225.01	Blockchain-based AI agents
P7006	Personal data AI agent
P3474	Autonomous-driving agent alignment
P4102	AI in chip design, incl. agentic workflows (guide)

ISO / IEC

JTC 1/SC 42 Artificial Intelligence

*No dedicated agentic-AI project yet.
Agent-relevant work:*

ISO/IEC 22989 Amd 2

AI terminology update; may define AI agents (AWI)

ISO/IEC 22989 Amd 1

Generative AI concepts & terms (DIS)

ISO/IEC 42102

AI system capability taxonomy (CD, with CEN JTC 21)

ISO/IEC 42105

Human oversight of AI systems

EU Standards

CEN-CENELEC JTC 21 · AI Act harmonised

prEN 18229-1

AI trustworthiness framework: logging, transparency, human oversight (AI Act Art. 12–14)

prEN 18282

Cybersecurity specifications for AI systems (AI Act Art. 15)

prEN ISO/IEC 42105

Human oversight, EN adoption

prEN ISO/IEC 42102

Capability taxonomy, joint ISO/CEN

6. Deployment

■ **Why it matters:** controlled scale reduces risk and builds confidence.

Pilot



Controlled rollout with a small cohort

Scale



Expand to more agents and teams

Monitor



Real-time alerts and dashboards

Handover



Operations and support processes

7. Operations

■ **Why it matters:** stay secure, compliant, and performed.

Monitor



Usage, anomalies,
performance

Manage



Updates, keys, access
reviews

Respond



Incidents and threats

Improve



Feedback, tuning, new
capabilities

How To Orchestrate in Production?

Fluxnova

An open-source process orchestration platform developed collaboratively by industry leaders.

Provides a standards-aligned, vendor-neutral alternative which reduces lock-in through full code access, open governance and transparent Apache 2.0 licensing. Flexible deployment options let teams run Fluxnova embedded into a microservice – on prem, or as containers in the cloud

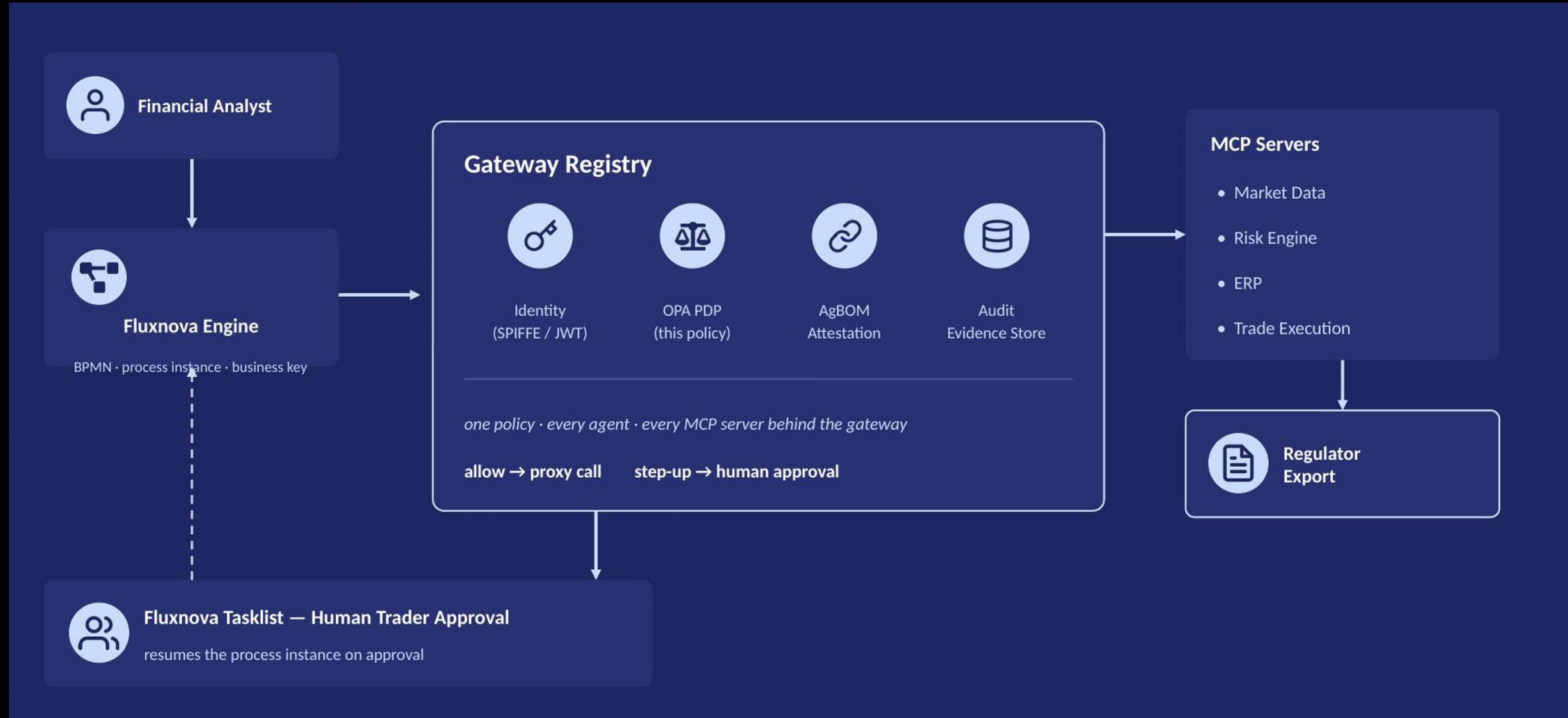


Backed by FINOS and The Linux Foundation, Fluxnova empowers digitization through process orchestration, helping organizations to increase straight through processing (STP) by automating complex processes involving multiple endpoints via BPM workflows.

GitHub Repo



Reference Architecture: Bringing it all Together



8. Retirement

■ **Why it matters:** remove risk and maintain a clear audit trail.

Decommission



Revoke access, archive data

Retain



Audit records, SBOMS,
evidence

Verify



Confirm no residual access

Close



Update registry and
documentation

The Result

Secure, Governed, Auditable, Ready for Scale!

Stronger Security



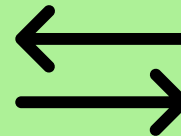
Identity, policy,
provenance, and audit

Regulatory Compliance



SPDX, evidence, full
traceability

Operational Efficiency



Controlled access,
lower risk

Business Enablement



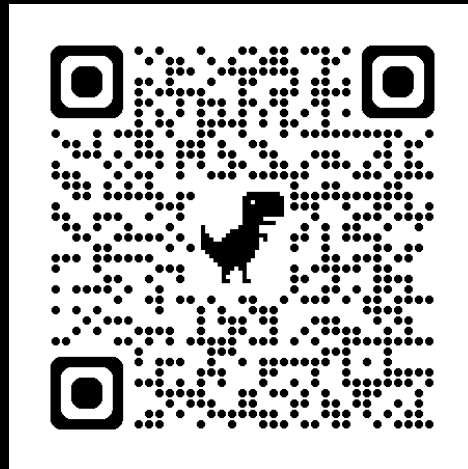
Trusted AI agents,
real financial impact

Call to Action!

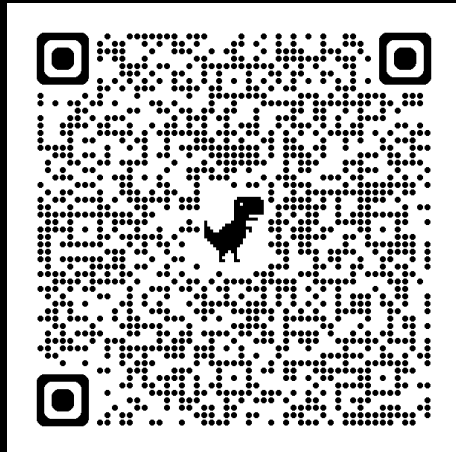
Jump into the deep-end and try it out yourself and let us know if something is broken.

- Resource Kit and White Paper with everything you need to start

- Resource Kit



- White Paper



Call to Action!

Join Related Open Source Working Groups

FINOS

AI Readiness SIG

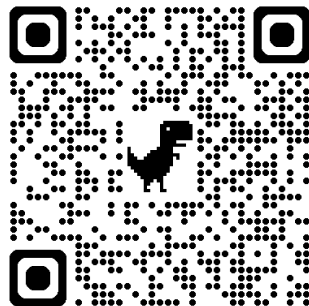
AI Governance Framework with an agentic risk catalogue, reference architectures and common controls for financial services.



OPENSSF

AI/ML Security WG

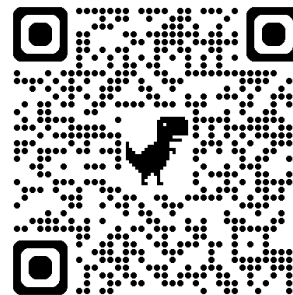
SAFE-MCP threat catalogue for agents, OpenSSF Model Signing, and secure guidance for AI code assistants.



SPDX

SPDX AI Working Group

AI and Dataset profiles that make AI BOMs a standard way to document models, data and dependencies.



AGENTIC AI FOUNDATION

AAIF Working Groups

Neutral home for MCP, AGENTS.md and goose: open, interoperable standards for AI agents.

